WYDZIAŁ TELEKOMUNIKACJI, INFORMATYKI I

ELEKTROTECHNIKI

Metody ochrony cyberprzestrzeni - projekt

Broken Access Control



Kopczyński Jakub

nr alb. 109636

Informatyka stosowana II st.

1. Broken Access Control

Broken Access Control to rodzaj luki w zabezpieczeniach, która pozwala nieautoryzowanym użytkownikom uzyskać dostęp do zasobów lub funkcji, do których nie powinni mieć uprawnień. Dotyczy kontroli dostępu do systemów informatycznych, aplikacji internetowych i baz danych. Broken Access Control może prowadzić do naruszenia poufności danych, nadużywania uprawnień i innych poważnych problemów związanych z bezpieczeństwem.

Typowe luki w kontroli dostępu obejmują:

- Naruszenie zasad uprawnień gdy dostęp powinien być przyznawany tylko dla określonych użytkowników.
- Omijanie kontroli dostępu poprzez modyfikowanie adresu URL
- Pozwolenie na przeglądanie lub edycję konta innej osoby poprzez podanie jego unikalnego identyfikatora
- Dostęp do API z brakującymi kontrolami dostępu dla POST, PUT i DELETE.
- Działanie jako użytkownik bez zalogowania lub działanie jako administrator po zalogowaniu się jako użytkownik.
- Manipulowanie metadanymi, np. odtwarzanie lub manipulowanie tokenem kontroli, plikiem cookie lub ukrytym polem w celu podniesienia uprawnień

Jak zapobiegać:

- Implementacja mechanizmów autoryzacji używanych w całej aplikacji nie tylko podczas logowania
- Wyłączenie wyświetlania katalogów serwerowych
- Rejestrowanie błędów kontroli dostępu na potrzeby powiadomień administratora
- Limit szybkości dostępu do API w celu zminimalizowania szkód spowodowanych przez narzędzia do automatycznego ataku.
- Identyfikator sesji powinien być unieważniony po wylogowaniu

Potrzeba	Działanie
Jako użytkownik systemu, chcę mieć możliwość uwierzytelnienia się przed dostępem do mojego konta, aby zapewnić bezpieczeństwo moich danych.	System autoryzacji wdrożony w całej aplikacji
Jako użytkownik systemu, oczekuję, że tylko uprawnione osoby będą miały dostęp do określonych zasobów lub funkcji	
Jako użytkownik, chcę mieć możliwość wylogowania się z aplikacji, aby zabezpieczyć swoje konto przed nieuprawnionym dostępem, gdy korzystam z publicznego komputera.	System logowania
Jako użytkownik, chcę otrzymać powiadomienie, jeśli ktoś próbuje uzyskać dostęp do mojego konta	Powiadomienie o ostatniej błędnej próbie logowania
Jako administrator chcę mieć pewność że moje API jest bezpieczne	Zabezpieczenie parametrów zapytań przed zmianami treści

2. Niezabezpieczony system (przeprowadzenie ataku)

Atak opiera się na wykorzystaniu luk w autoryzacji użytkownika, system nie posiadający odpowiedniego mechanizmu autoryzacji oraz widoczne, jasno sygnalizujące działanie parametry jest skrajnie podatny na ataki prowadzące do przejęcia kont użytkownika czy np. dostęp do funkcjonalności administratora.



Niezabezpieczony system rejestracji pozwala użyć dowolnego hasła, brak wymogu odpowiednio długiego i bezpiecznego hasła ułatwia ataki prowadzące do przejęcia kontroli nad kontem. Jeśli nie wymagamy na użytkowniku odpowiedniego hasła często wykorzystuje on niebezpieczne hasło.



Mimo wykorzystania formularza logowania, jeśli nie jest on powiązany z autoryzacją w całym systemie nie ma on praktycznego sensu. Jeśli po zalogowaniu przekazywany jest jedynie niezaszyfrowany parametr dostęp jest nie ograniczony. Wystarczy podać dowolny numer istniejącego już użytkownika aby przejąć konto. Dodatkowy brak powiadomień o błędnym logowaniu uniemożliwia wykrycie ewentualnych prób ataku.



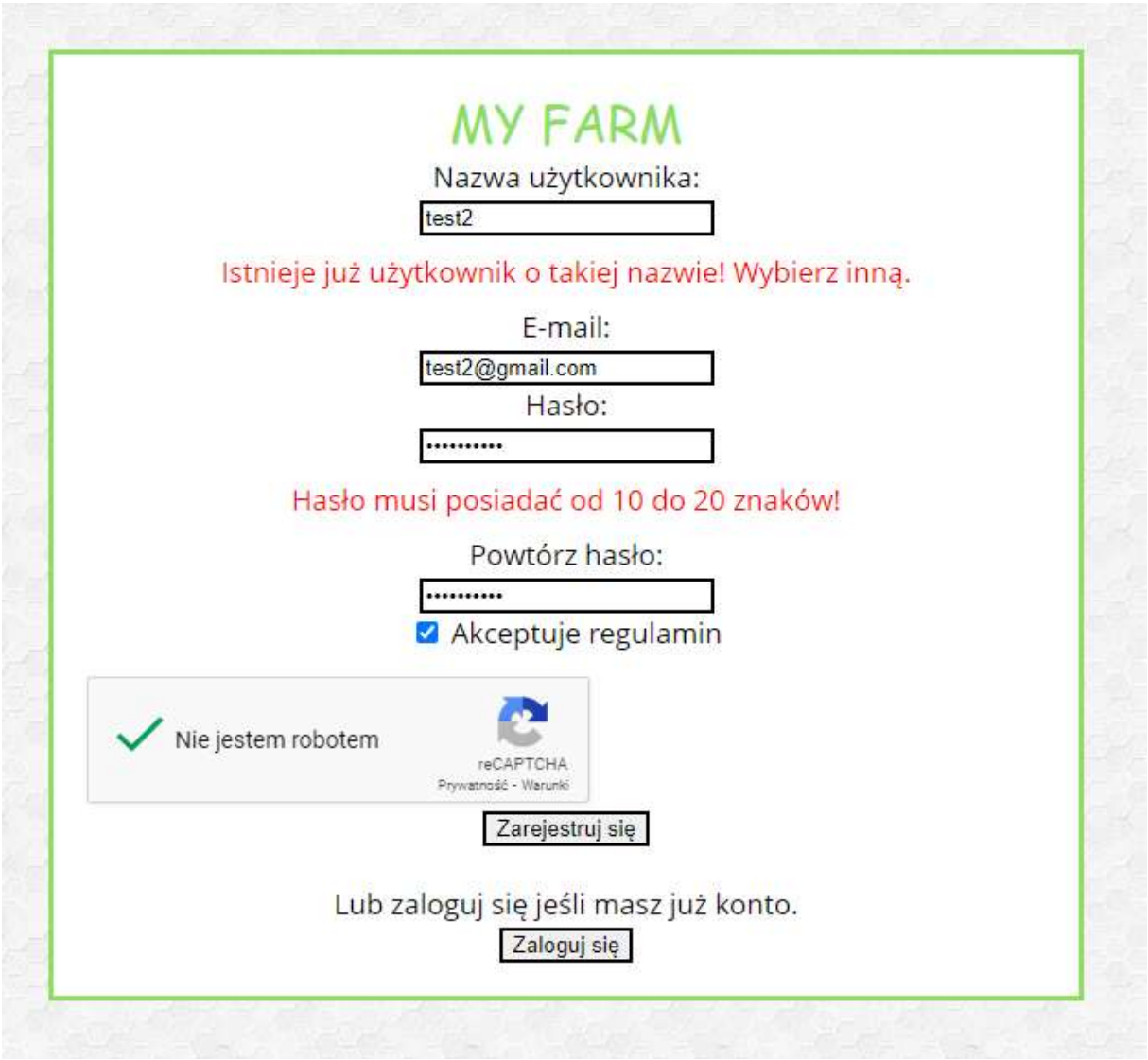
W niezabezpieczonym systemie użytkownik o ID = 9 może zmienić parametr ID na dowolnego innego użytkownika i używać jego konta bez konieczności autoryzacji. Podawanie parametrów w niezabezpieczonej formie np. szyfrowanie jest skrajnie niebezpieczne. Dodatkowo brak systemu autoryzacji na każdej podstronie umożliwia dowolne przemieszczanie się atakującego po systemie.



Tak samo wygląda atak w przypadku API, jeśli parametry nie są szyfrowane lub najlepiej przekazywane metodą POST atakujący może w łatwy sposób odgadnąć jego działanie i wykorzystać do ataku.

Brak możliwości wylogowania użytkownika prowadzi do możliwości nieautoryzowanego dostępu np. w przypadku logowania na komputerze publicznym.

3. Zabezpieczenie systemu



Formularz rejestracji wymagający od użytkownika użycia silnego hasła utrudnia ewentualne ataki słownikowe czy brute force. Dodatkowo zabezpieczenie reCAPTCHA uniemożliwia masowe tworzenie kont przez boty. Hasła w bazie są dodatkowo hashowane. Umożliwiło to wdrożenie opcji wylogowania użytkownika. Dodatkowo zmienne sesyjne wygasają wraz z upływem czasu dzięki czemu nawet pozostawione zalogowane konto po pewnym czasie zostanie automatycznie wylogowane.



W zabezpieczonej wersji systemu wdrożono system autoryzacji oparty o zmienne sesyjne tak aby uniemożliwić eksploracje systemu bez logowania natomiast parametry identyfikujące użytkownika zostają przekazane metodą post dzięki czemu nie są łatwo dostępne do manipulacji. Podobnie w przypadku API parametry powinny być szyfrowane.

4. Wnioski

Ataki typu Broken Access Control są dość prostym typem ataków mimo to trafiły w 2021r. na pierwsze miejsce zagrożeń na stronie OWASP.org. Niezabezpieczone systemy są bardzo podatne na atak który może prowadzić do bardzo dużych szkód. Brak odpowiedniej autoryzacji, zabezpieczeń w całym systemie czy jawne parametry stanowią ogromną przestrzeń do ataków.

Aby zabezpieczyć się przed tymi atakami należy:

- Zaimplementować mechanizmy kontroli dostępu używane w całej aplikacji.
- Wyłączyć wyświetlanie katalogów serwera oraz upewnić się, że metadane takie jak .git nie znajdują się w głównym katalogu sieciowym.
- Szyfrować lub ukryć parametry i zmienne przekazywane w systemie.
- Należy rejestrować błędy kontroli dostępu i w razie potrzeby informować administratora.
- Ustalić limity szybkości dostępu do interfejsów API.
- Zmienne sesyjne muszą zostać unieważnione po wylogowaniu.